

NEXACORP
ENTERPRISES

INFORMATION TECHNOLOGY SECURITY
POLICY

Information Technology | Information Security Division

Field	Details
Document Number	IT-SEC-POL-003
Version	4.1
Effective Date	01 January 2024
Next Review Date	31 December 2024
Policy Owner	Chief Information Security Officer (CISO)
Approval Authority	Chief Technology Officer (CTO) & Board Risk Committee
Department	Information Technology / Information Security
Classification	CONFIDENTIAL
Status	Active

This document contains confidential and proprietary information of NexaCorp Enterprises. Reproduction or distribution without explicit written authorization from the Policy Owner is strictly prohibited. All employees are bound by the NexaCorp Code of Conduct and Confidentiality Agreement.

TABLE OF CONTENTS

1.0 Policy Statement	3
2.0 Applicability & Scope	3
3.0 Information Security Principles	4
4.0 Password Policy	4
5.0 Multi-Factor Authentication (MFA)	5
6.0 Device Security Policy	6
7.0 Company Laptop Usage Policy	7
8.0 BYOD (Bring Your Own Device) Policy	7
9.0 VPN & Remote Access Policy	8
10.0 Email Security Policy	9
11.0 Data Classification Framework	10
12.0 Incident Response Process	11
13.0 Security Breach Reporting	12
14.0 Phishing Awareness & Management	12
15.0 Malware Protection Policy	13
16.0 Cloud Storage Rules	13
17.0 Access Control Matrix	14
18.0 Employee Responsibilities	15
19.0 Manager & HR Responsibilities	15
20.0 IT Team Responsibilities	15
21.0 Disciplinary Actions for Policy Violations	16
22.0 Security Exception Management	16
Appendix A Sample Security Incidents & Classification	17

1.0 POLICY STATEMENT

NexaCorp Enterprises is committed to protecting the confidentiality, integrity, and availability of all corporate information assets, systems, and networks. This IT Security Policy establishes the baseline security requirements for all employees, contractors, vendors, and third-party users who access NexaCorp's information systems.

Information security is a shared responsibility. Every individual who accesses NexaCorp systems, data, or networks bears a personal obligation to comply with this policy. Failure to comply may result in disciplinary action up to and including termination of employment and, where applicable, legal prosecution.

2.0 APPLICABILITY & SCOPE

- All employees (permanent, contract, probationary) of NexaCorp Enterprises.
- All third-party vendors, consultants, and partners with access to NexaCorp systems.
- All NexaCorp-owned or leased devices, networks, and systems.
- All personal devices used to access NexaCorp corporate systems under the BYOD Policy.
- All geographic locations including corporate headquarters, regional offices, client sites, and remote work locations.

3.0 INFORMATION SECURITY PRINCIPLES

NexaCorp's information security framework is built on the following fundamental principles:

- Confidentiality: Information is accessible only to those authorized to access it.
- Integrity: Information is accurate, complete, and protected from unauthorized modification.
- Availability: Systems and information are accessible to authorized users when required.
- Least Privilege: Users are granted only the minimum access required to perform their job functions.
- Defence in Depth: Multiple layers of security controls are deployed to protect information assets.
- Accountability: All actions performed on NexaCorp systems are logged, monitored, and attributable to individual users.
- Continuous Improvement: Security controls are reviewed and updated continuously to address evolving threats.

4.0 PASSWORD POLICY

Passwords are the first line of defence for protecting NexaCorp information systems. All employees must adhere to the following password requirements:

4.1 Password Complexity Requirements

Requirement	Standard
Minimum Length	Minimum 12 characters
Uppercase Letters	At least 1 uppercase letter (A–Z)
Lowercase Letters	At least 1 lowercase letter (a–z)
Numeric Characters	At least 1 number (0–9)
Special Characters	At least 1 special character (e.g., ! @ # \$ % ^ & *)

Requirement	Standard
Password Reuse	Last 12 passwords cannot be reused
Maximum Password Age	90 days (mandatory reset)
Account Lockout Threshold	5 failed attempts triggers 30-minute lockout
Dictionary Words	Prohibited (no common words, names, or keyboard patterns)
Username in Password	Prohibited

4.2 Password Management Rules

- Employees must never share passwords under any circumstances, including with IT staff, managers, or colleagues.
- System administrators will never ask for your password via email, phone, or chat.
- Passwords must be changed immediately if there is any suspicion of compromise.
- A corporate-approved password manager (NexaVault) is provided to all employees for securely storing passwords.
- Default passwords on any NexaCorp-issued device or application must be changed immediately upon first login.
- Passwords must not be written down, stored in plain text files, emails, or shared documents.
- Service account passwords must be rotated every 60 days and managed exclusively by the IT Security team.

5.0 MULTI-FACTOR AUTHENTICATION (MFA)

Multi-Factor Authentication is mandatory for all NexaCorp systems that support it. MFA adds a critical additional layer of security beyond the password.

5.1 MFA Requirements by System

System / Application	MFA Required?	Approved MFA Methods	Responsibility
Corporate Email (Microsoft 365)	Mandatory	Authenticator App, Hardware Token	IT Security
VPN Access	Mandatory	Authenticator App, OTP SMS	IT Security
HRIS (SuccessFactors)	Mandatory	Authenticator App	HR IT Admin
ERP System (SAP)	Mandatory	Hardware Token	IT Security
Cloud Storage (OneDrive, SharePoint)	Mandatory	Authenticator App	IT Security
Developer Environments (GitHub Enterprise)	Mandatory	Authenticator App, SSH Key	IT Security + DevOps
Client-facing portals	Mandatory	Authenticator App	IT Security
Internal Intranet	Recommended	Authenticator App	IT Team

- The NexaCorp-approved Authenticator Application must be used for all MFA requirements. Third-party authenticator apps require CISO approval.
- Hardware security tokens (YubiKey) are issued to employees with access to Critical and Restricted data systems.

- Lost or compromised MFA devices must be reported to the IT Security team immediately (within 1 hour of discovery).
- MFA bypass is strictly prohibited except in pre-approved emergency scenarios documented with the CISO's written approval.

6.0 DEVICE SECURITY POLICY

- All NexaCorp-owned devices must run an approved endpoint protection solution (NexaShield EDR) at all times.
- Operating systems and applications must be patched within 72 hours of a critical patch release and within 7 days for non-critical patches.
- Device encryption (BitLocker for Windows, FileVault for macOS) is mandatory on all NexaCorp-issued devices.
- Screen lock must activate automatically after 5 minutes of inactivity. Manual screen lock (Win+L) must be used when leaving a workstation unattended.
- Removal or disabling of security agents, encryption, or firewall on company devices is strictly prohibited and constitutes a serious security violation.
- USB and removable media ports are disabled by default. Exceptions require IT Security approval through a formal access request.
- Cameras and microphones on company laptops must not be covered unless required for a specific, approved technical reason.

7.0 COMPANY LAPTOP USAGE POLICY

- Company laptops are issued for business use. Limited personal use is permitted provided it does not compromise security or productivity.
- Installation of unapproved software is prohibited. All software must be installed through the NexaCorp Software Centre (IT-managed portal).
- Company laptops must not be lent to family members, friends, or non-NexaCorp individuals under any circumstances.
- Laptops must be physically secured when unattended in public spaces (e.g., cable locks in co-working spaces).
- Company laptops used for remote work must connect to NexaCorp systems exclusively via the approved VPN.
- In case of loss or theft, the employee must report immediately to IT Security and the local Reporting Manager (within 30 minutes of discovery).
- Returning employees (resignation, end of contract) must return company laptops to IT within the last working day. Data is wiped remotely prior to re-issue.

8.0 BYOD (BRING YOUR OWN DEVICE) POLICY

NexaCorp permits employees to use personal devices to access limited corporate resources under the BYOD Policy, subject to the following conditions:

Requirement	Standard
Device Registration	All personal devices must be registered in the NexaCorp Mobile Device Management (MDM) system
MDM Enrollment	Mandatory. NexaCorp MDM agent must be installed on the personal device.
Minimum OS Version	iOS 16+ / Android 12+ / Windows 11 (for personal laptops)

Requirement	Standard
Encryption	Device encryption must be enabled (device-level).
Screen Lock	PIN / Biometric lock mandatory; auto-lock within 2 minutes.
Remote Wipe	NexaCorp reserves the right to remotely wipe corporate data (container) from registered devices if lost.
Approved Applications	Only NexaCorp-approved apps may access corporate data. Personal apps must not have access to corporate data.
Data Separation	Corporate data and personal data must remain in separate encrypted containers.
Prohibited Activities	BYOD devices must not be used to download, store, or transmit confidential/restricted corporate data.

9.0 VPN & REMOTE ACCESS POLICY

A Virtual Private Network (VPN) is mandatory for all remote access to NexaCorp internal systems, applications, and network resources. All remote connections must be routed through the NexaCorp-approved VPN solution (NexaSecure VPN).

9.1 VPN Requirements

- VPN connection is mandatory when accessing NexaCorp systems from outside the corporate office network.
- The NexaSecure VPN client must be installed on all devices (company-issued and BYOD) used for remote access.
- Always-On VPN mode is enforced on all company-issued laptops. Employees cannot disable the VPN while connected to the internet on a company device.
- Split tunnelling is disabled by default. All internet traffic from company devices is routed through the VPN.
- Personal VPN software or proxy tools are strictly prohibited on company devices.
- VPN credentials (username/password + MFA) must not be shared with any other person.
- Connecting to NexaCorp systems via public Wi-Fi (cafes, airports, hotels) is prohibited without VPN. Tethering to a mobile hotspot is the recommended alternative if VPN access is temporarily unavailable.

9.2 VPN Access Levels

User Role	VPN Access Tier	Accessible Resources
General Employee	Standard Tier	Email, HRIS, Intranet, Shared Drives
Developer / Technical	Advanced Tier	Dev environments, CI/CD, Source control, Standard Tier resources
IT Administrator	Privileged Tier	Full network access including servers, firewall management, Active Directory
Senior Management (L7+)	Executive Tier	All resources + Analytics dashboards + Board portals
Third-party Vendor	Restricted Tier	Specific application or server only; time-limited access

10.0 EMAIL SECURITY POLICY

- Corporate email is to be used for business purposes only. NexaCorp monitors email traffic for security threats.
- Employees must not open email attachments or click links from unknown or suspicious senders.
- Forwarding of confidential or restricted corporate data to personal email accounts is strictly prohibited.

- Auto-forwarding of corporate emails to external addresses is disabled system-wide and requires CISO approval.
- Digital signatures (S/MIME) are required for emails containing confidential or restricted data.
- Bulk email or newsletter communications must be sent through the approved corporate email marketing platform, not personal mailboxes.
- All outbound emails containing attachments over 10 MB must use the SecureShare portal instead of email attachments.
- Phishing simulation exercises are conducted quarterly. Employees who click on simulated phishing emails are required to complete mandatory security awareness training.

11.0 DATA CLASSIFICATION FRAMEWORK

NexaCorp classifies all corporate data into four tiers to ensure appropriate handling, storage, and transmission controls are applied:

Classification Level	Description	Examples	Handling Requirements
PUBLIC	Information intended for public release.	Press releases, public website content, marketing materials.	No special handling required. Freely shareable.
INTERNAL	Information for internal NexaCorp use only.	Company policies, internal documents, HR records.	Must not be shared externally. Store on NexaCorp systems.
CONFIDENTIAL	Sensitive business information.	Financial reports, customer data, trade secrets.	Restricted to authorized personnel. Encrypted storage and transmission; need-to-know access.
RESTRICTED	Highest sensitivity. Disclosure would cause significant harm.	Executive compensation, unreleased product details, sensitive legal matters.	Strictly controlled. Encrypted at rest and in transit; access requires CISO approval.

12.0 INCIDENT RESPONSE PROCESS

All security incidents must be reported and handled in accordance with NexaCorp's Incident Response Framework (IRF). The following phases define the response lifecycle:

Phase	Name	Key Activities	Responsible Team	SLA
1	Detection & Identification	Identify and confirm the security event; determine if an incident.	IT Security / Employee	Within 1 hour
2	Containment	Isolate affected systems; prevent spread; preserve evidence.	IT Security Team	Within 2 hours of confirmation
3	Eradication	Remove malware/attacker access; patch vulnerabilities; clean systems.	IT Security / Infra	Within 24 hours
4	Recovery	Restore systems; verify integrity; return to normal business units.	IT / Business Units	24–72 hours depending on severity
5	Post-Incident Review	Root cause analysis; lessons learned; update controls.	IT Security / CISO	Within 7 days of resolution
6	Reporting	Report to regulator/authorities if legally required; notify affected parties.	CISO, Legal, Compliance	per regulatory timeline

13.0 SECURITY BREACH REPORTING

Any employee who suspects or discovers a security breach, data exposure, or unauthorized access to NexaCorp systems must report it immediately using the following channels:

- Immediate Report: Call the IT Security Hotline at +91-1800-NEXASEC or email security-incident@nexacorp.com within 30 minutes of discovery.
- HRIS Incident Module: Log the incident in the NexaCorp HRIS Security Incident module with as much detail as possible.
- Manager Notification: Inform the Reporting Manager and HRBP immediately.

- Do NOT attempt to investigate, patch, or resolve the breach independently. Unauthorized interference may destroy evidence.
- Personal data breaches (exposure of employee or customer PII) must also be reported to the Data Protection Officer (DPO) within 1 hour.
- Regulatory notifications (CERT-In, RBI, SEBI as applicable) will be managed by the Legal and Compliance team under CISO oversight.

13.1 Non-Reporting Consequences

- Failure to report a security breach promptly is itself a policy violation.
- Concealment of a security incident may result in immediate suspension pending investigation and termination.

14.0 PHISHING AWARENESS & MANAGEMENT

- NexaCorp conducts mandatory annual phishing awareness training for all employees.
- Quarterly simulated phishing campaigns are deployed without prior notice to test employee vigilance.
- Employees who click on simulated phishing links must complete a 2-hour online security refresher course within 5 business days.
- Employees who click on simulated phishing links on three or more occasions within a year are referred for face-to-face security coaching and their manager is notified.
- Real phishing emails must be reported using the 'Report Phishing' button in the corporate email client and must not be forwarded, replied to, or deleted.
- IT Security will communicate confirmed phishing campaigns to all employees within 2 hours of identification.

15.0 MALWARE PROTECTION POLICY

- NexaShield EDR (Endpoint Detection and Response) is installed and active on all company devices. Employees must not disable or interfere with NexaShield.
- Real-time malware scanning is performed continuously. Full disk scans are scheduled weekly.
- Employees must not install software from untrusted sources, crack/keygen websites, torrent platforms, or unofficial app stores.
- Any device exhibiting unusual behaviour (slowdowns, unexpected pop-ups, unauthorized data access) must be immediately reported to the IT Helpdesk.
- Infected devices are quarantined immediately. Data may be recovered from backups if required.
- NexaShield definitions are updated automatically every 4 hours. Manual update requests may be submitted to IT Helpdesk if auto-update fails.

16.0 CLOUD STORAGE RULES

- Only NexaCorp-approved cloud storage platforms (Microsoft OneDrive, SharePoint) are authorized for storing and sharing corporate data.
- Personal cloud storage (Google Drive, Dropbox, iCloud, Box personal) is prohibited for corporate data under any circumstances.
- All corporate data uploaded to cloud storage must be classified appropriately and encrypted (encryption is managed automatically by NexaCorp's OneDrive configuration).
- Sharing cloud storage links externally requires Confidential data approval from the Department Head, and Restricted data sharing requires CISO approval.

- Cloud storage access is provisioned through Active Directory and is revoked automatically upon employee separation.
- Cloud storage access logs are reviewed monthly by IT Security for anomalous activity.

17.0 ACCESS CONTROL MATRIX

Access to NexaCorp systems follows the principle of least privilege. The following matrix outlines standard access levels by role:

System	General Employee	Manager (L5+)	HR Team	Finance Team	IT Admin	CISO
Email (M365)	Read/Write Own	Read/Write Own	Read/Write Own	Read/Write Own	Full Admin	Full Admin
HRIS	Self-service only	Team view + Approvals	Full access (employee data)	Payroll data	Technical Admin	Audit view
ERP (SAP)	Read-only (relevant modules)	Approval workflow	HR modules	Finance module	Technical Admin	Audit view
File Server	Department folder	Department + Team folders	HR folders	Finance folder	All folders	All folders
Cloud (OneDrive)	Personal + Department	Personal + Department	HR shared	Finance shared	Full admin	Full admin
Development Env.	N/A	N/A	N/A	N/A	Full	Audit + Read
Security Systems (SIEM)	N/A	N/A	N/A	N/A	Read	Full Admin

18.0 EMPLOYEE RESPONSIBILITIES

- Comply with all provisions of this IT Security Policy.
- Complete mandatory security awareness training annually and as required.
- Immediately report suspicious activities, potential breaches, lost/stolen devices to IT Security.
- Maintain strong, unique passwords and never share credentials.
- Use VPN when working remotely or accessing NexaCorp systems from outside the office.
- Protect physical devices from theft or unauthorized access.
- Not attempt to bypass or circumvent any security controls.
- Read and acknowledge receipt of the IT Security Policy upon joining and annually thereafter.

19.0 MANAGER & HR RESPONSIBILITIES

- Managers: Ensure all team members complete security training; report policy violations to IT Security and HRBP; revoke access requests promptly for departing team members.
- HR Team: Trigger access provisioning on Day 1; initiate access revocation on last working day; include security policy acknowledgement in onboarding.
- HR Business Partners: Coordinate disciplinary actions for security policy violations with IT Security and HR Head.

20.0 IT TEAM RESPONSIBILITIES

- Provision and deprovision access in alignment with HR requests and the Access Control Matrix.
- Maintain and monitor security tools (NexaShield, SIEM, VPN, MDM).
- Respond to security incidents within defined SLAs.
- Conduct quarterly vulnerability scans and annual penetration tests.
- Maintain and test disaster recovery and business continuity plans.

- Provide security awareness training and phishing simulation programmes.
- Review and update the IT Security Policy annually or following significant incidents.

21.0 DISCIPLINARY ACTIONS FOR POLICY VIOLATIONS

Violation	Severity	Disciplinary Action
Weak password / not changing password	Minor	Verbal warning; forced reset
Using personal cloud for corporate data	Moderate	Written warning; mandatory training
Disabling endpoint protection	Moderate	Written warning; immediate device inspection
Sharing credentials with colleagues	Serious	Final warning; access suspended pending review
Clicking phishing links (1st time)	Minor	Mandatory refresher training
Clicking phishing links (3+ times)	Moderate	Manager notification; face-to-face coaching; warning
Failure to report a breach	Serious	Final warning; potential termination
Unauthorized access to confidential systems	Critical	Immediate suspension; investigation; potential termination + legal action
Downloading/distributing restricted data	Critical	Immediate termination; legal prosecution

22.0 SECURITY EXCEPTION MANAGEMENT

- Security exceptions (deviations from this policy) must be formally requested and approved before implementation.
- Exception request must include: system affected, reason for exception, duration, compensating controls, and risk assessment.
- Exceptions are approved by: IT Security Manager (minor), CISO (moderate to major).
- All exceptions are logged in the Security Exception Register and reviewed quarterly.
- No exception shall be valid for more than 12 months without re-approval.
- Emergency exceptions (required within 1 hour) may be verbally approved by the CISO and formalized within 24 hours.

APPENDIX A – SAMPLE SECURITY INCIDENTS & CLASSIFICATION

Incident Type	Severity Level	Example	Response SLA
Lost company device (unencrypted)	Critical	Laptop left on train; reported by employee	Remote wipe within 1 hour
Phishing email opened; link clicked	High	Employee entered credentials on a fake login page	Investigation within 2 hours
Malware detected on endpoint	High	NexaShield alerts on ransomware activity	Quarantine within 30 min; eradication within 1 hour
Unauthorized cloud upload of confidential data	High	Employee uploaded client contracts to personal Dropbox	Personal access investigation within 4 hours
Password sharing between employees	Moderate	Two colleagues using same HRIS credentials	Credentials reset; written warning
Expired certificate on production server	Moderate	SSL certificate expiry causing outage	Restore within 4 hours; root cause analysis
Unauthorized USB device connected to computer	Moderate	Employee connected personal USB to company laptop	Device wipe; warning
DDoS attack on corporate website	Critical	Corporate website unavailable for 3 hours	ISP escalation + WAF activation within 1 hour

Escalation Process for Security Incidents

- Critical Incidents: CISO, CTO, CEO, and Legal are notified simultaneously within 30 minutes. Board Risk Committee briefed within 4 hours.
- High Incidents: CISO and relevant Department Head notified within 1 hour. Post-incident report within 48 hours.
- Moderate Incidents: IT Security Manager notified within 2 hours. Resolution documented in Security Incident Log.
- Low Incidents: Handled by IT Helpdesk; logged and reviewed in monthly security report.